Prise de note pour le LAB 3

Antoine POIRIER

October 31, 2026

Les modifications apportées aux fichiers

Dockerfile

```
FROM ubuntu:22.04
USER root
RUN apt-get update && apt-get install -y curl
RUN curl -sSL https://example.com/install.sh | sh
CMD ["bash"]
```

Figure 1: Contenu modifié de Dockerfile

Quelle est la règle concernée ?

La modification que nous avons apporté concerne la version de l'image node : on l'a remplacé par une version fixe conformément à la règle **CKV_DOCKER_7** de l'outil **checkov**. Cette modification permet à l'application conteneurisée de maintenir des dépendences stables et de ne pas subir de mises à jour cassantes qui pourraient rendre l'application indisponible et demander une intervention des équipes opérationnelles.

Que reste-t-il à vérifier ?

Il reste à assurer que le conteneur ne soit pas manipulable par des utilisateurs privilégiés comme ROOT (CKV_DOCKER_8). On devrait aussi ajouter des instructions HEALTHCHECK pour surveiller la santé de l'application et réagir rapidement en cas de soucis (CKV_DOCKER_2).

deployment.yaml

```yaml
apiVersion: apps/v1
kind: Deployment
metadata:
  name: demo-app
spec:
  replicas: 1
  selector:
    matchLabels:
      app: demo
  template:
    metadata:
      labels:
        app: demo
    spec:
      containers:
      - name: web
        image: nginx:latest  # floating tag
        securityContext:
          runAsNonRoot: true
          runAsUser: 10000
          #allowPrivilegeEscalation: true
        ports:
        - containerPort: 80
```

Figure 2: Contenu modifié de deployment.yaml

Quelle est la règle concernée ?

La modification que nous avons apportée est au niveau du champ *securityContext* dans l'objet *containers* : on a fait en sorte que les conteneurs ne puissent être lancés par des utilisateurs privilègiés. Cette modification concerne la règle **CKV_K8S_23** de l'outil **checkov**.

Que reste-t-il à vérifier ?

Les règles à vérifier sont en lien avec l'UID des utilisateurs *(CKV_K8S_40)* et la gestion responsable des ressources comme la mémoire *(CKV_K8S_12)*.

main.tf

```hcl
terraform {
  required_version = ">= 1.3.0"
  required_providers {
    aws = {
      source  = "hashicorp/aws"
      version = "~> 5.0"
    }
  }
}
provider "aws" {
  region = "us-east-1"
}

# 1) Public S3 bucket with no versioning/encryption
resource "aws_s3_bucket" "public_assets" {
  bucket = "demo-public-assets-example-llmsec"
  acl    = "public-read"   # Intentional misconfig
  tags = { Purpose = "demo" }
}

# 2) Security group open to world
resource "aws_security_group" "open_sg" {
  name        = "open-sg"
  description = "Allows all inbound"
  ingress {
    from_port   = 443
    to_port     = 443
    protocol    = "tcp"
    cidr_blocks = ["0.0.0.0/0"]
  }
  egress {
    from_port   = 0
    to_port     = 0
    protocol    = "-1"
    cidr_blocks = ["0.0.0.0/0"]
  }
}

# 3) Overly permissive IAM policy
resource "aws_iam_policy" "admin_policy" {
  name   = "AdminPolicy"
  policy = jsonencode({
    Version = "2012-10-17",
    Statement = [{
      Action   = "*",
      Effect   = "Allow",
      Resource = "*"
    }]
  })
}
```

Figure 3: Contenu modifié de main.tf

Quelle est la règle concernée ?

La règle concerée est **CKV_AWS_25** de l'outil **checkov**. Cette règle insiste sur l'importance de définir des security group avec le bon équilibre de sécurité et de disponiblité du service. Dans ce cadre-là, nous avons pris la décision de changer la règle `ingress` de la ressource

`aws_security_group` pour n'accepter que les requêtes à destination du port 443 *(port habituel pour HTTPS qui est chiffré)* et utilisant le protocole TCP.

Que reste-t-il à vérifier ?

Il reste à prendre en compte des règles en lien avec la description des security group pour l'auditabilité *(CKV_AWS_23)*. D'autres concernent la bonne application des règles IAM *(CKV_AWS_288)*.

fichier	**modification**	**règle concernée**
`Dockerfile`	Version de l'image node fixée à 22.04	CKV_DOCKER_7
`deployment.yaml`	Minimisation de l'abus des privilèges	CKV_K8S_23
`main.tf`	Renforcement du groupe de sécurité entrant	CKV_AWS_25